

Evaluation of Applicable Information Security and Data Protection Standards for Pampered Pets

Abinel Madzivire

Introduction

Pampered Pets is a small retail organisation that handles customer information and is likely to process payment-card transactions. Although its operations are relatively small, the organisation remains subject to legal and industry requirements relating to personal data and payment security. Of the standards and guidance considered, the UK General Data Protection Regulation (UK GDPR) and the Payment Card Industry Data Security Standard (PCI DSS) are the most directly applicable. The HMG Cybersecurity Guidelines, including Cyber Essentials and the National Cyber Security Centre (NCSC) 10 Steps to Cyber Security, are not necessarily mandatory for the organisation but provide valuable good-practice controls. In contrast, the Health Insurance Portability and Accountability Act (HIPAA) would not ordinarily apply because Pampered Pets is not a United States healthcare organisation and there is no indication that it processes protected health information.

Applicable standards

UK GDPR

The UK GDPR is clearly applicable because Pampered Pets processes personal information relating to customers and employees. Customer information may include names, email addresses, telephone numbers, addresses and order details, while employee records may contain further personal information. Under the UK GDPR, organisations must follow the principles of lawfulness, fairness and transparency;

purpose limitation; data minimisation; accuracy; storage limitation; integrity and confidentiality; and accountability (ICO, 2026a).

The security principle is particularly important. The Information Commissioner's Office (ICO) requires organisations to implement appropriate technical and organisational measures to protect personal information against unauthorised access, loss, alteration or disclosure (ICO, 2026b). Pampered Pets should therefore ensure that customer information received through email, stored on computers or retained in physical records is properly protected.

The organisation must also demonstrate that it has an appropriate lawful basis for processing personal data and that customers understand how their information will be used. The ICO emphasises that organisations should be clear, open and honest with individuals about the collection and processing of their information (ICO, 2025).

PCI DSS

PCI DSS would apply if Pampered Pets accepts debit or credit card payments. This is highly likely for a modern retail business, particularly one conducting face-to-face transactions. PCI DSS is intended to protect cardholder information and applies to merchants regardless of their size or transaction volume (PCI SSC, 2026a).

The exact PCI DSS requirements depend on how payments are processed. For example, if Pampered Pets uses a standalone approved card terminal and does not electronically store cardholder information, its compliance requirements may be relatively limited. The PCI Security Standards Council provides different Self-Assessment Questionnaires (SAQs) according to the merchant's payment environment (PCI SSC, 2026b).

A particularly significant risk would arise if customers sent card details through ordinary email. PCI SSC guidance explains that where payment account numbers are sent or received through email or other messaging technologies, those communication systems may become part of the PCI DSS scope and must be protected according to applicable requirements (PCI SSC, 2025). Consequently, customers should never be encouraged to send payment-card details through standard email.

HMG Cybersecurity Guidelines and Cyber Essentials

The HMG cybersecurity guidance discussed by Sutton (2021) includes the Cyber Essentials Scheme and the NCSC 10 Steps to Cyber Security. These would not normally be compulsory for a small private pet retailer unless required contractually, for example when supplying certain public-sector organisations. Nevertheless, they provide a useful framework against which Pampered Pets' security maturity can be assessed. Sutton (2021) also emphasises that information risk should not be addressed through a single control; instead, organisations frequently require a combination of strategic, tactical and operational controls.

Cyber Essentials focuses on five fundamental technical controls: firewalls, secure configuration, security update management, user access control and malware protection (NCSC, 2026a). These controls would be highly appropriate for Pampered Pets because of its small size and relatively straightforward IT environment.

The NCSC 10 Steps to Cyber Security additionally covers risk management, staff engagement and training, asset management, secure configuration, vulnerability management, identity and access management, data security, logging and monitoring, incident management and supply-chain security (NCSC, 2026b). Although the full

framework is principally aimed at larger organisations, the NCSC states that its underlying principles can also be applied to smaller organisations.

HIPAA

HIPAA would not apply to Pampered Pets under the assumptions made in this assessment. HIPAA protects individually identifiable health information handled by specified US healthcare organisations and their business associates. Protected Health Information relates to an individual's health, healthcare provision or payment for healthcare (HIPAA Guide, 2026).

Since Pampered Pets is assumed to operate in the United Kingdom as a retail business rather than as a healthcare provider, HIPAA compliance would therefore not be required. Even if the company sold veterinary-related products, this would not itself make the business a HIPAA-covered entity.

Evaluation of Pampered Pets against the applicable standards

Based on the information provided in the case study, Pampered Pets appears to have a relatively informal information-security environment. This is understandable for a four-person organisation, but small size does not remove its legal or contractual responsibilities.

From a UK GDPR perspective, one of the first areas to examine would be how customer information submitted by email is collected, stored and subsequently deleted. If customer emails remain indefinitely in staff mailboxes, there could be a breach of the storage limitation principle. Similarly, collecting unnecessary customer information would conflict with data minimisation. The ICO requires organisations to collect only the personal data that is genuinely required and retain it only for as long as necessary (ICO, 2026a).

I would therefore carry out a data audit identifying what personal data Pampered Pets holds, why it is required, where it is stored, who can access it, how long it is retained and with whom it is shared. I would also review its privacy notice, lawful bases for processing, retention procedures, customer access procedures and breach-management arrangements.

Technical testing should include checking password and account controls, workstation security, antivirus or endpoint protection, firewall configuration, software patching, backups and wireless-network security. This approach reflects NCSC guidance, which recommends understanding the organisation's hardware, software, accounts and data assets as an essential part of cyber-risk management (NCSC, 2026c).

Access to systems should be reviewed to establish whether each employee has an individual account and only the permissions required to perform their role. Shared passwords would be particularly undesirable because they reduce accountability and make it difficult to determine who accessed or altered information. The NCSC recommends regularly reviewing account privileges and removing unnecessary access rights (NCSC, 2026d).

For PCI DSS, I would establish exactly how debit and credit card payments are accepted and whether Pampered Pets stores, processes or transmits cardholder information. The payment terminal configuration and payment provider should be reviewed, including evidence that the payment service provider is PCI DSS compliant. PCI SSC guidance indicates that payment devices should be reviewed during assessment to ensure that security settings have not been disabled and that sensitive authentication information is not improperly retained (PCI SSC, 2026c).

The appropriate PCI DSS Self-Assessment Questionnaire should then be completed with the merchant's acquiring bank or payment provider. For example, a business using only an appropriate standalone payment terminal without electronic card-data storage may qualify for a relatively limited SAQ, whereas more complex payment arrangements may require a broader assessment (PCI SSC, 2026b).

Compliance should therefore not be treated as a one-off checklist exercise. Regular reviews should establish whether controls continue to function effectively. Sutton (2021) highlights the importance of risk identification, vulnerability assessment, risk treatment, monitoring and review as parts of an effective information-risk-management programme.

Recommendations

Pampered Pets should first develop a basic information-security and data-protection policy setting out responsibilities for handling customer, employee and payment information. Alice, as owner/manager, should retain overall responsibility for ensuring that security and privacy requirements are followed.

A data inventory and retention schedule should be created. Customer information should only be collected where necessary for orders or other legitimate business purposes and should be securely deleted when no longer required. A clear privacy notice should explain what personal information is collected, why it is processed, its retention period, relevant third-party recipients and customers' data-protection rights.

Technical security should be strengthened through the Cyber Essentials controls. Computers should be securely configured, supported software should be kept up to date, unnecessary applications and administrator privileges should be removed, firewalls should be enabled and anti-malware protection should be maintained. Cyber

Essentials certification would provide a practical and proportionate security target for a small organisation such as Pampered Pets. The current Cyber Essentials technical requirements continue to emphasise these five fundamental controls (NCSC, 2026a).

Individual staff accounts should be introduced, supported by strong passwords and multi-factor authentication, particularly for email, cloud services and administrative accounts. Staff should not share passwords. Access to customer and financial data should follow the principle of least privilege.

Email security is particularly important because some customers submit orders electronically. Employees should receive awareness training concerning phishing, malicious attachments, fraudulent payment requests and accidental disclosure of customer information. NCSC guidance stresses that appropriately trained employees can help prevent incidents and recognise suspicious activity when a positive security culture exists (NCSC, 2026e).

Pampered Pets should also prohibit customers and employees from transmitting complete card details through ordinary email. Card payments should instead be processed through a PCI DSS-compliant terminal or approved payment provider. If card details are unintentionally received by email, the organisation should follow a documented procedure for securely dealing with the information.

Regular backups should be implemented and recovery tested. The NCSC advises organisations to plan for backup and recovery so that essential data and services can be restored following incidents such as ransomware attacks (NCSC, 2026f).

An incident-response and personal-data-breach procedure should also be created. Employees need to know whom to inform when a suspicious email, lost device, malware infection, unauthorised disclosure or payment-security incident occurs.

Effective incident preparation reduces operational, financial and reputational consequences (NCSC, 2026g).

Finally, Pampered Pets should conduct periodic internal reviews. This could include the ICO's small-business data-protection self-assessment, annual PCI DSS self-assessment where applicable, regular vulnerability and patch checks, review of staff permissions, inspection of payment terminals, backup-restoration testing and annual security-awareness training. The ICO specifically provides a data-protection compliance assessment designed for small businesses and sole traders (ICO, 2026c).

Assumptions

This evaluation makes several assumptions because the case study does not provide every technical or operational detail. It is assumed that Pampered Pets operates in the United Kingdom and therefore falls within the scope of the UK GDPR. It is also assumed that the business collects customer names and contact details when processing email orders and retains employee information.

It is further assumed that the organisation accepts debit or credit card payments. PCI DSS would only apply to the relevant payment-card environment; if Pampered Pets accepted cash only, PCI DSS would not apply. The assessment assumes that it uses a conventional third-party card-payment terminal rather than developing or operating its own online payment platform.

It is assumed that Pampered Pets does not operate as a healthcare provider or handle US healthcare information and therefore is not subject to HIPAA. It is also assumed that the organisation is not a UK government body or government contractor requiring mandatory compliance with specific HMG security standards. Consequently, Cyber

Essentials and the NCSC guidelines have been treated as good-practice frameworks rather than statutory requirements.

Finally, because no detailed network architecture, privacy documentation, payment arrangements or technical security configuration has been provided, conclusions about existing compliance are preliminary. A formal compliance assessment would require examination of systems, policies, payment processes, staff practices and documentary evidence.

Conclusion

The principal standards applicable to Pampered Pets are the UK GDPR and PCI DSS, while Cyber Essentials and the HMG/NCSC cybersecurity guidelines provide appropriate supporting security controls. HIPAA is not applicable under the circumstances described. The greatest priorities should therefore be protecting customer personal information, securing payment transactions, restricting access to systems, maintaining secure and updated devices, training staff and introducing documented incident-management and data-retention procedures. Rather than regarding compliance as a one-off activity, Pampered Pets should adopt an ongoing risk-management process involving assessment, implementation, monitoring and periodic review.

References

HIPAA Guide (2026) *HIPAA for Dummies – HIPAA Guide*. Available at: <https://www.hipaaguide.net/hipaa-for-dummies/> (Accessed: 4 September 2026).

Information Commissioner's Office (ICO) (2025) *Principle (a): Lawfulness, fairness and transparency*. Available at: <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/> (Accessed: 4 September 2026).

Information Commissioner's Office (ICO) (2026a) *Data protection principles, definitions and key terms*. Available at: <https://ico.org.uk/for-organisations/advice-for-small-organisations/getting-started-with-gdpr/> (Accessed: 4 September 2026).

Information Commissioner's Office (ICO) (2026b) *Principle (f): Integrity and confidentiality (security)*. Available at: <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/> (Accessed: 4 September 2026).

Information Commissioner's Office (ICO) (2026c) *How well do you comply with data protection law: an assessment for small business owners and sole traders*. Available at: <https://ico.org.uk/for-organisations/advice-for-small-organisations/> (Accessed: 4 September 2026).

National Cyber Security Centre (NCSC) (2026a) *Cyber Essentials*. Available at: <https://www.ncsc.gov.uk/cyberessentials/overview> (Accessed: 4 September 2026).

National Cyber Security Centre (NCSC) (2026b) *10 Steps to Cyber Security: Risk management*. Available at: <https://www.ncsc.gov.uk/collection/10-steps> (Accessed: 4 September 2026).

National Cyber Security Centre (NCSC) (2026c) *10 Steps to Cyber Security: Asset management*. Available at: <https://www.ncsc.gov.uk/collection/10-steps/asset-management> (Accessed: 4 September 2026).

National Cyber Security Centre (NCSC) (2026d) *10 Steps to Cyber Security: Identity and access management*. Available at: <https://www.ncsc.gov.uk/collection/10-steps/identity-and-access-management> (Accessed: 4 September 2026).

National Cyber Security Centre (NCSC) (2026e) *10 Steps to Cyber Security: Engagement and training*. Available at: <https://www.ncsc.gov.uk/collection/10-steps/engagement-and-training> (Accessed: 4 September 2026).

National Cyber Security Centre (NCSC) (2026f) *10 Steps to Cyber Security: Architecture and configuration*. Available at: <https://www.ncsc.gov.uk/collection/10-steps/architecture-and-configuration> (Accessed: 4 September 2026).

National Cyber Security Centre (NCSC) (2026g) *10 Steps to Cyber Security: Incident management*. Available at: <https://www.ncsc.gov.uk/collection/10-steps/incident-management> (Accessed: 4 September 2026).

PCI Security Standards Council (PCI SSC) (2025) *Are entities allowed to request that cardholder data be provided over end-user messaging technologies?* Available at: <https://www.pcisecuritystandards.org/> (Accessed: 4 September 2026).

PCI Security Standards Council (PCI SSC) (2026a) *Information for merchants*. Available at: <https://www.pcisecuritystandards.org/merchants/> (Accessed: 4 September 2026).

PCI Security Standards Council (PCI SSC) (2026b) *Assessing the security of your cardholder data*. Available at: <https://www.pcisecuritystandards.org/> (Accessed: 4 September 2026).

PCI Security Standards Council (PCI SSC) (2026c) *PCI DSS frequently asked questions: Payment devices*. Available at: <https://www.pcisecuritystandards.org/> (Accessed: 4 September 2026).

Sutton, D. (2021) *Information Risk Management: A Practitioner's Guide*. 2nd edn. Swindon: BCS, The Chartered Institute for IT.